

Lớp 4 - Sao lưu và phục hồi: Thực hiện nguyên tắc 3-2-1: 3 bản sao, 2 loại phương tiện lưu trữ khác nhau, 1 bản ngoài site (off-site/cloud). Kiểm tra phục hồi thực tế định kỳ tối thiểu mỗi quý.

Lớp 5 - Giám sát liên tục (SOC): Sử dụng dịch vụ SOC thuê ngoài theo mô hình MSSP đối với SME không có đội IT nội bộ. Viettel SOC đang cung cấp dịch vụ giám sát 24/7 với chi phí phù hợp quy mô SME.

Lớp 6 - Kiểm soát luồng dữ liệu ra ngoài (Outbound Traffic Control / DNS Filtering): Đây là lớp bảo vệ thường bị bỏ qua nhưng không kém phần quan trọng, hoạt động theo giả định thực tế: các lớp trên đã bị qua mặt, thiết bị đã nhiễm mã độc. Khi đó, mã độc sẽ "gọi về nhà" (C2 - Command & Control) để nhận lệnh và âm thầm rút dữ liệu ra ngoài. Giải pháp DNS Filtering và kiểm soát outbound traffic phát hiện và chặn đứng các kết nối đến máy chủ độc hại theo thời gian thực - ngăn dữ liệu rời khỏi tổ chức ngay cả khi endpoint đã bị xâm nhập. Khác với tường lửa truyền thống chỉ kiểm soát chiều vào, lớp này tập trung vào chiều ra - nơi thiệt hại thực sự xảy ra. Hiện đã có các thiết bị chuyên dụng tích hợp công nghệ này, phù hợp triển khai cho cả SME lẫn hạ tầng trọng yếu.

Bảng 2: Ưu tiên triển khai giải pháp kỹ thuật theo quy mô doanh nghiệp

Quy mô	Ưu tiên cao nhất	Ưu tiên thứ hai	Ghi chú
Siêu nhỏ (<10 người)	MFA + Backup 3-2-1	Traffic Filtering (Lớp 6)	Chi phí thấp, hiệu quả cao
Nhỏ (10–50 người)	EDR + MFA + Backup	NGFW + Outbound Control	Xem xét dịch vụ MSSP
Vừa (50–200 người)	EDR + NGFW + SOC	Lớp 6 + Network Seg.	Cần chính sách bảo mật văn bản
Lớn (>200 người)	SOC 24/7 + SIEM + Lớp 6	Pentest định kỳ	Nên có CISO hoặc đội IT bảo mật

4.3. Trụ cột 3: Tuân thủ pháp lý và quản trị dữ liệu

Tuân thủ pháp luật là nghĩa vụ và cũng là lợi thế cạnh tranh. Để tuân thủ Luật 91/2025/QH15 và Luật 116/2025/QH15, doanh nghiệp cần thực hiện ngay: